

Network & Information Security

Chapter 1 — Condensed Study Notes | Sem VI

1. Information Security

Information security is the practice of protecting information by mitigating risks. It protects systems and the information processed, stored, and transmitted by them from **unauthorized access, use, disclosure, disruption, modification, or destruction**.

CIA Triad — 3 Core Principles

Confidentiality	Keeping data secret from unauthorized eyes. Achieved through encryption and access controls.
Integrity	Ensuring data is accurate and unaltered. Achieved via digital signatures and change management.
Availability	Ensuring authorized users can access data when needed. Achieved through backups and disaster recovery.

Components of InfoSec

People	Trained employees; security awareness programs.
Processes	Policies, procedures, risk management, incident response.
Technology	Firewalls, antivirus, encryption, cloud security, endpoint security.

2. Threats, Attacks & Vulnerabilities

Threat

A **threat** is a possible security violation that may exploit a system's weakness. Sources: accidents, natural disasters, human error, or intentional actions.

Unstructured	Inexperienced individuals using simple tools (e.g., password crackers).
Structured	Organized, targeted attempts by skilled/motivated hackers.
External	Originate outside the organization; via internet or remote access.
Internal	Caused by users who already have authorized access.

Types of Attack

Active Attack	Attacker alters, damages, or controls the system (e.g., malware, data theft). Like someone breaking in and tampering.
Passive Attack	Attacker silently monitors or steals information without changes. Like someone secretly reading messages.

Active Attack Subtypes

Attack Type	Description
-------------	-------------

Masquerade	Attacker disguises as another user/entity to gain unauthorized access. Variants: username/password, IP, website, email masquerade.
Message Modification	Parts of a message are altered without permission to change its meaning. Breaks data integrity.
Repudiation	Attacker performs a damaging action (financial transaction, message) and later denies it. Types: message, transaction, data repudiation.
Replay Attack	Attacker captures a valid message and re-transmits it to produce an authorized effect. Saved data is later reused maliciously.
DoS Attack	Floods a target with traffic/requests to exhaust resources and block legitimate users. Sub-types: Flood attacks, Amplification attacks.

Threat vs Attack — Quick Comparison

Threat	Attack
Possible danger or risk	Actual harmful action
Intentional OR unintentional	Always intentional
May or may not be malicious	Always malicious
Harder to detect	Easier to detect
Prevented by controlling vulnerabilities	Cannot be stopped by vulnerability control alone

Vulnerabilities

Weaknesses in a system that give threats the opportunity to compromise assets. Types:

Hardware	Flaws in physical devices. Causes: old systems, unprotected storage, unencrypted devices. Prevention: encrypt devices, strong authentication, secure storage, update firmware.
Software	Bugs/flaws in code. Causes: lack of input validation, unverified uploads, XSS, unencrypted data. Prevention: regular patching, secure coding, antivirus, input validation.
Network	Weaknesses in network design/config. Causes: unsecured Wi-Fi, open ports, MITM vectors, misconfigured firewalls. Prevention: SSL/TLS, WPA3 Wi-Fi, firewalls+IDS/IPS, close unused ports.
Procedural	Weak organizational processes. Causes: default configs, improper access controls, inadequate logging. Prevention: change defaults, RBAC, robust logging, Principle of Least Privilege.
Human	Risks from behavior (phishing, weak passwords). Causes: social engineering, negligence, lack of awareness. Prevention: security training, strong passwords + MFA, regular audits, phishing awareness.

3. Security Services & Mechanisms

Security Services

Service	Purpose & How
Data Confidentiality	Prevents disclosure to unauthorized users. Method: encryption, secure channels.
Data Integrity	Ensures data is not altered. Sub: Anti-change (no unauthorized modification) + Anti-replay (blocks resent old messages). Method: Hash functions, MACs.
Authentication	Confirms identity. Sub: Peer entity authentication (verifies parties) + Data origin authentication (confirms source). Method: passwords, biometrics, digital certs.
Non-repudiation	Prevents denial of actions. Sub: Proof of origin (sender cannot deny) + Proof of delivery (receiver cannot deny). Method: digital signatures.

Security Mechanisms

Mechanism	Description
Encipherment	Hides data using algorithms (cryptography). Converts info into unreadable form; level depends on algorithm.
Access Control	Prevents unauthorized data access. Methods: passwords, firewalls, PINs.
Notarization	Trusted third party mediates communication; keeps records to resolve later disputes.
Data Integrity	Appends a checksum/value to data; verified at receiver to confirm no alteration.
Authentication Exchange	Identity confirmed via TCP/IP two-way handshaking.
Bit Stuffing	Extra bits added to transmitted data; checked at receiver using Even/Odd parity.
Digital Signature	Sender encrypts signature data with private key; receiver verifies with sender's public key to confirm identity.

4. Cryptography & Steganography

Cryptography

Cryptography (Greek: "secret writing") — science of transforming messages to make them secure. Key properties:

Confidentiality	Only intended recipient can access information.
Non-repudiation	Sender cannot deny sending a message.
Integrity	Unauthorized modification is detectable.
Authentication	Confirms identities of sender and receiver.
Adaptability	Continuously evolves against new threats.
Interoperability	Enables secure communication across systems.

Steganography

Steganography (Greek: "covered writing") — conceals the *existence* of a message (vs cryptography which hides its *content*).

Process: (1) Choose cover medium (image, audio, video, text) → (2) Optionally encrypt message → (3) Embed using a technique → (4) Transmit stego-object → (5) Receiver extracts.

Common techniques: **LSB (Least Significant Bit)** encoding, Frequency Domain embedding, Bit Plane hiding.

5. Conventional Cryptographic Techniques — Substitution Ciphers

Caesar Cipher

Shifts each letter by a fixed key value. A=0, B=1, ... Z=25.

Example: Key=4, Plaintext: HELLO → LIPPS

Encryption: $C = (P + \text{key}) \bmod 26$ | Decryption: $P = (C - \text{key}) \bmod 26$

Monoalphabetic Cipher

Each plaintext letter maps to a **single fixed** cipher letter across the entire message. Simple but breakable via frequency analysis.

Polyalphabetic Cipher (e.g. Vigenère)

Uses **multiple substitution alphabets**; each plaintext letter can map to different cipher letters depending on key position.

Example: Plaintext: ATTACKATDAWN, Keyword: LEMON → each letter shifted by the corresponding keyword letter value.

Monoalphabetic vs Polyalphabetic

Monoalphabetic	Polyalphabetic
One-to-one mapping	One-to-many mapping
Key independent of position	Key depends on position in stream
Examples: additive, multiplicative, affine	Examples: Autokey, Playfair, Vigenère, Hill, One-Time Pad, Enigma
Simpler, weaker security	Much stronger security

Playfair Cipher

First practical **digraph substitution cipher**. Invented 1854 by Charles Wheatstone; named after Lord Playfair. Encrypts **pairs of letters** (digraphs) using a 5×5 key matrix (J is omitted; I replaces J).

Plaintext split into digraphs; if odd, append Z; if pair has same letter, insert bogus letter (X or Z).

Same column rule	Replace each letter with the one directly below it (wrap to top).
Same row rule	Replace each letter with the one directly to its right (wrap to left).
Rectangle rule	Form rectangle with two letters; replace with letters at horizontal opposite corners.

Example: Plaintext: instrumentsz → Ciphertext: gatlmzclrqtx

Hill Cipher

Polygraphic substitution based on **linear algebra**. Letters represented as numbers mod 26 (A=0 ... Z=25).

Encryption: block of n letters (as vector) × invertible n×n key matrix (mod 26).

Decryption: multiply ciphertext vector by the **inverse** of the key matrix.

Example (n=3): Plaintext: ACT, Key matrix: GYBNQKURP → Ciphertext: POH

One-Time Pad (OTP)

Theoretically **unbreakable** cipher. Requirements:

- Key must be **randomly generated** and at least as long as the message.
- Key is used **only once**, then discarded.

Example: HELLO (7 4 11 11 14) + Key MONEY (12 14 13 4 24) = TSYPM. Decryption: reverse the addition.

6. Transposition Ciphers

Rearranges (permutes) the **positions** of letters rather than substituting them. No letter values change.

Rail Fence Cipher

Simplest transposition cipher; also called **zigzag cipher**. Plaintext written diagonally across multiple 'rails'; read off row by row.

Single Columnar (Block) Transposition

Plaintext written row-by-row into a grid; columns read in the order defined by the alphabetical rank of the key letters.

Double Columnar Transposition

Applies Single Columnar transposition **twice** using two different keys for stronger security.

Example: Key1: FIRM, Key2: WORD, Plaintext: MEETMEATDAWN → Ciphertext: ETWMAEDTAMEN

Decryption reverses Key2 grid → recovers intermediate text → reverses Key1 grid → plaintext.

7. Block & Stream Ciphers | DES & AES

Block vs Stream Cipher

Block Cipher	Stream Cipher
Encrypts fixed-size chunks (blocks), e.g., 128 bits	Encrypts bit-by-bit or byte-by-byte
Uses complex substitutions and permutations	Generates keystream XORed with plaintext
Example: AES	Example: RC4
Good for large stored data	Ideal for real-time, continuous data streams

DES (Data Encryption Standard)

- Symmetric block cipher; input = output = **64 bits**.
- Processes groups of bits together (block cipher).
- Found vulnerable to powerful attacks → **replaced by AES**.

AES (Advanced Encryption Standard)

- Successor to DES; current standard for symmetric encryption.
- Block size: 128 bits; key sizes: 128, 192, or 256 bits.
- Operations per round: **SubBytes** (S-box substitution), **ShiftRows**, **MixColumns**, **AddRoundKey**.

8. Hash Functions

Mathematical operations that map any data to a **fixed-length bit string (hash value)**. Used in cryptocurrency, password security, and communication security.

Properties of Cryptographic Hash Functions

Deterministic	Same input always produces the same hash output.
Fast Computation	Processes inputs quickly; practical for large datasets.
Pre-image Resistance	Computationally infeasible to reverse-engineer original input from hash.
Collision Resistance	Near-impossible for two different inputs to produce the same hash.
Avalanche Effect	Even a 1-bit change in input causes a drastically different hash output.

Popular Hash Algorithms

Algorithm	Notes
-----------	-------

MD5	Historically popular; now INSECURE — collision attacks are easy. Not recommended for security applications.
SHA-1	Improved over MD5 but deprecated; practical collision attacks discovered. No longer used for SSL/TLS or digital signatures.
SHA-2 (256/512)	Current INDUSTRY STANDARD. Strong collision and pre-image resistance. Used in HTTPS, blockchain, password hashing.
SHA-3 (Keccak)	Latest NIST standard; uses unique sponge construction. Resistant to attacks targeting SHA-2.
BLAKE2 / BLAKE3	High-speed alternatives. BLAKE3 supports parallel processing; ideal for modern systems needing speed + security.

SHA-1 Working Steps

- Initialization: Set five variables h0–h4 with predefined values.
- Pre-processing: Append '1' bit + '0' bits + original message length.
- Processing: Divide into 512-bit chunks; each chunk into 16×32 -bit words; extend to 80×32 -bit words.
- Main Loop: Update temporary variables and hash values per word.
- Finalization: Combine hash values → 160-bit final hash output.

9. Public Key Cryptography & RSA

Public Key (Asymmetric) Cryptography

Uses **two keys**: a public key (shared freely) and a private key (kept secret).

- Data encrypted with the **public key** can only be decrypted with the **private key**.
- Also called **asymmetric cryptography** due to use of two different keys.

TLS/SSL Usage

- Website SSL/TLS certificate contains the public key; private key stays on the origin server.
- TLS handshake: public key cryptography authenticates the server and agrees on session keys.
- Key exchange algorithms (RSA, Diffie-Hellman) establish symmetric session keys for ongoing communication.
- New session keys per session prevent decryption of past sessions even if a key is later compromised.

RSA Algorithm

Key Generation	Choose primes $p, q \rightarrow n = p \times q \rightarrow \phi(n) = (p-1)(q-1) \rightarrow$ choose e coprime to $\phi(n) \rightarrow$ compute d such that $(e \times d) \bmod \phi(n) = 1$. Public key: (n, e) Private key: (n, d)
Encryption	$c = m^e \bmod n$
Decryption	$m = c^d \bmod n$
Example	$p=61, q=53 \rightarrow n=3233, \phi(n)=3120, e=17, d=2753$. Encrypt 'H'(72): $72^{17} \bmod 3233 = 2103$ Decrypt 2103: $2103^{2753} \bmod 3233 = 72$ (H)

10. Digital Certificates, Signatures & PKI

Digital Certificate

A public key certificate that establishes a cryptographic link between an entity and their public key. Issued by a **Certificate Authority (CA)**.

Contains: certified public key, certificate holder metadata, identity info, and CA's digital signature.

- Used to verify user authenticity and enable encrypted replies.
- Enables SSL/TLS connections between web browsers and servers.

Digital Signature

Mathematical scheme to verify authenticity of digital messages/documents. Based on RSA and public key cryptography.

Creation	Sender encrypts signature data with their private key .
Verification	Receiver decrypts with sender's public key — only valid if keys match.
Purpose	Verifies sender identity and document integrity. Used in software distribution, financial transactions, contract management.

Public Key Infrastructure (PKI)

Security framework that **issues and manages digital certificates** to establish trust on digital networks.

- Provides unique digital identities to users, devices, and systems.
- Secures communication using public/private key pairs.
- Prevents Man-in-the-Middle (MITM) attacks by verifying key ownership.
- Ensures confidentiality, integrity, and authenticity of data.